

Countermeasures for Combating Cyber Attacks in Korea

August 7, 2007

Heung-Youl Youm, Ph.D.
Professor, Soonchunhyang University
Rapporteur, ITU-T SG17 Q.9
Project Manager of Information Security, MIC/IITA, Korea

Agenda

1

Overview of Information Security

2

Detailed response activities for cyber attacks

3

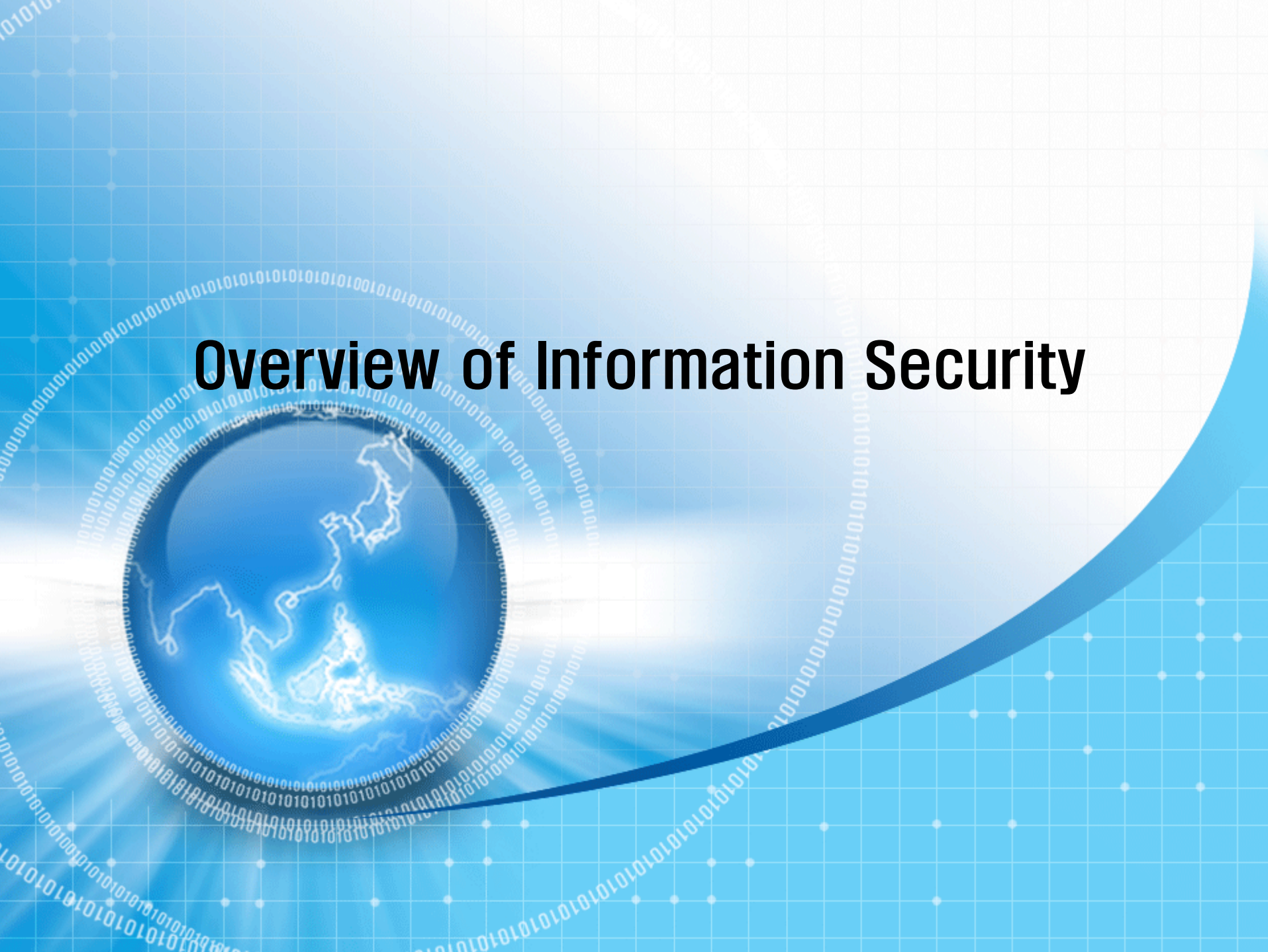
Vision and goals

4

Conclusions



Overview of Information Security



Information Security structure in Korea



<http://www.mic.go.kr>



Ministry of Information and Communication

- Develop basic strategies & policies for Critical Infrastructure protection, Incident responses, Privacy Protection, ISMS&CC Evaluation, R&D, etc

<http://www.kisa.or.kr>



KISA

- Real Policy Enforcement agency
- Incident Response by Korea Internet Security Center
- Critical Infrastructure Protection
- CC evaluation for Information Security Products
- Privacy Protection

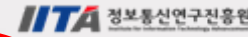
<http://www.etri.re.kr>



ETRI

- R&D in the information security area
- Technology developed by ETRI is transferred to Industry
- R&D for infrastructure protection and application security

<http://www.iita.re.kr>



IITA

- Plan&manage MIC-supported R&D projects
- Five ITRC projects for developing human resource in university/graduate school
- The Information Security is selected as one of Top 10 priority IT R&D areas by MIC

<http://www.tta.or.kr>



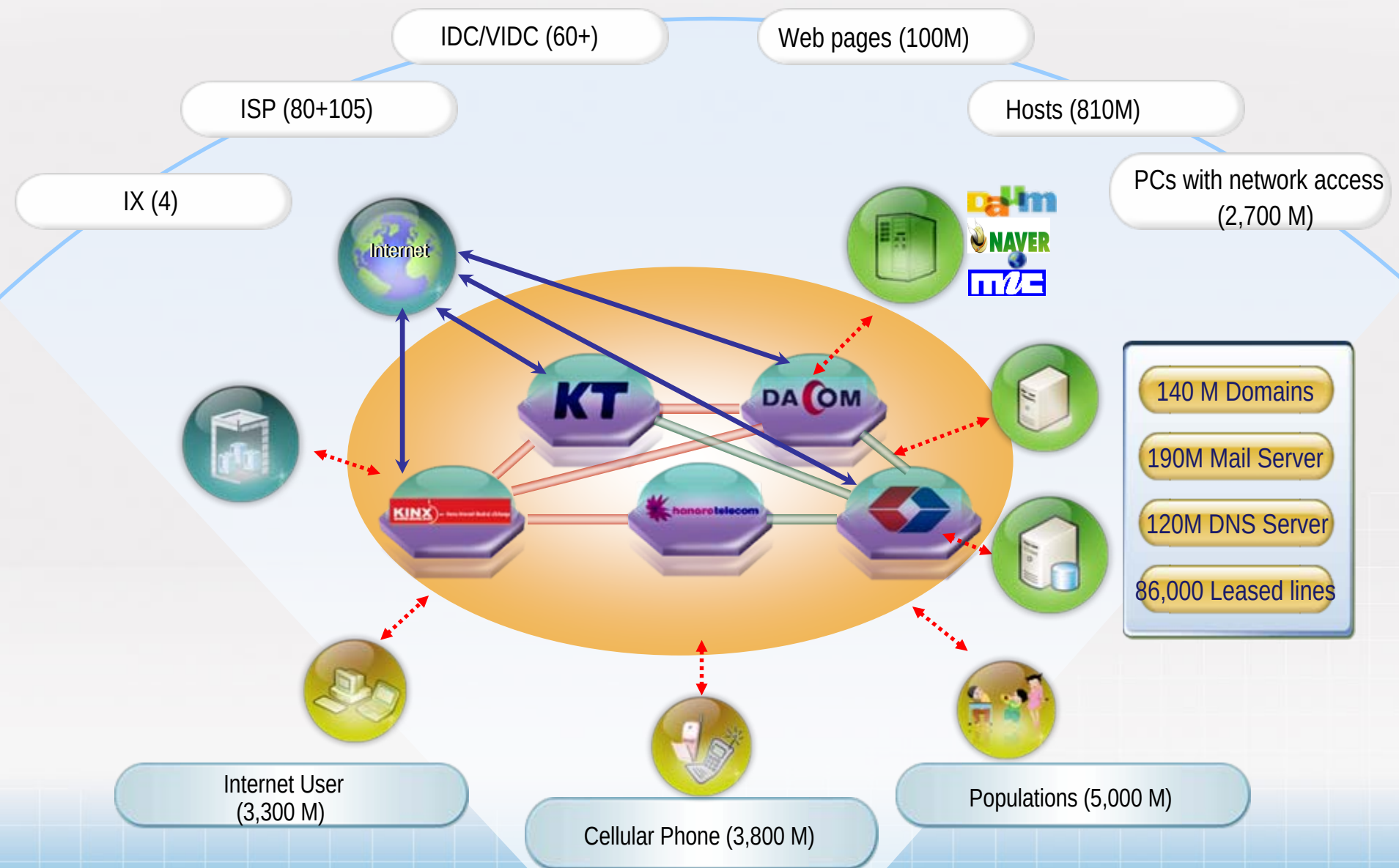
TTA

- Development of IS Standards
- 4 PGs in Technical Committee 1: Infrastructure Protections, Internet security, Biometrics including IC cards, Digital Right Management

- **Three acts have been enacted by MIC :**
 - Act on Promotion of Information and Communication Network; Utilization and information Protection ;
 - Act on Digital Signature;
 - Act on Critical Infrastructure Protection.
- **Acts on Digital Signature**
 - Enacted on July 1, 1997, recently revised in December 31, 2005.
 - To provide the fundamental items for using digital signatures in order to ensure the security and trust of electronic document and promote using it.
 - It has articles describing Definition on digital signature, Licensed Certification Authority, Public Key Certificate, Security and Trust for Certification Service, Electronic Certification Policy, etc.

- Act on Promotion of Information and Communication Network Utilization and information Protection
 - Enacted on 1999, recently revised on July 1, 2007.
 - To promote the Information and Communication Network Utilization and provide environments for utilizing the information and communication network securely.
 - It has articles describing Information and Communication Network Utilization, promoting the electronic document transfer through relay server, Privacy information protection, User protection, information and communication network protection, and Penalties.
- Act on Critical Infrastructure Protection
 - Enacted on January, 2001, revised recently on December, 2002.
 - Basic act for protecting the critical infrastructure from the cyber attacks.
 - It has articles describing assignment of critical infrastructure, Establishment of protection plan for CII, Proactive measure and Response against incidents, Information sharing and agency for information sharing, Information security consulting company, and legal Responsibilities and penalties.

Targets protected



- **IT Threats environments**

- Wireless-based network and services are increasing.
- Society is becoming increasingly dependant on the Internet.
- The discovery of vulnerabilities in protocols and application programs is increasing gradually.
- The convergence in networks, terminals and services is continuing to increase.
- The gap between the security requirement and enforcement is widening with the increase in complexity.
- Laws, legal actions and regulations do not harmonize with recent global attack trends.

- **Recent threats trends**

- Damages from malicious code infections in websites are increasing.
- Attack target moved to end users in order to steal the personal information like ID/PW for the financial benefits using Key-logger.
- Using infected web page as the means to hack other uninfected web pages.
- Rising threats due to giant zombie networks (BOT-net).
 - 6,049,594 distinct BOT-infected computers between the second half of 2006, a 29 percent increase from the previous 6 months period, according to Symantec Internet security Report.
- Combination of Phishing and Pharming technology is emerging.
- Zero-day attacks and Ransom attacks have emerged recently.
 - 12 zero-day vulnerabilities in the second half of 2006 by Symantec.

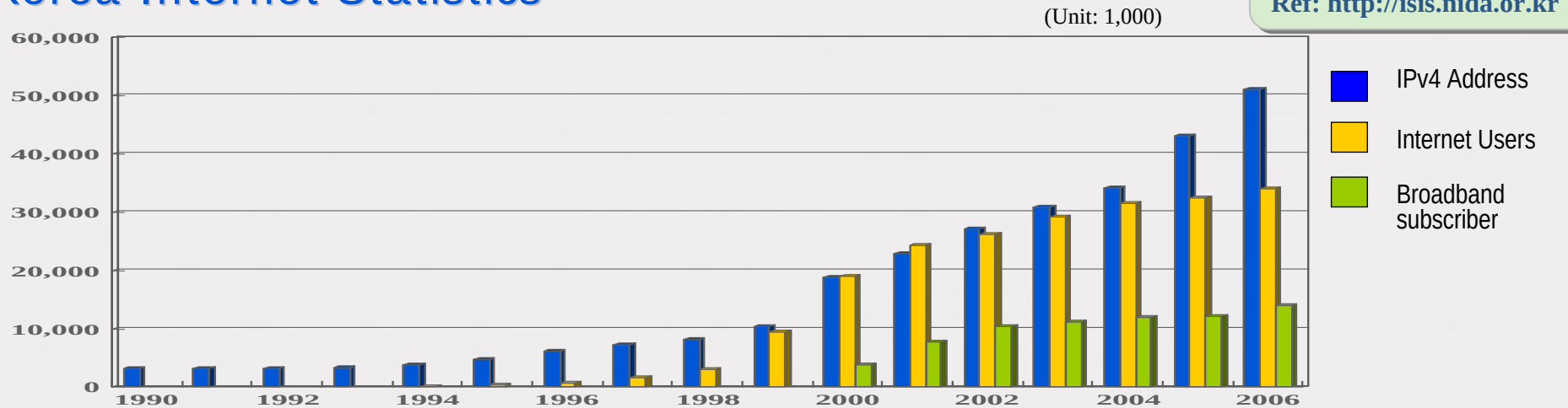
- **Korea's General Internet statistics**

[http://isis.nida.or.kr/index_unssl.jsp]

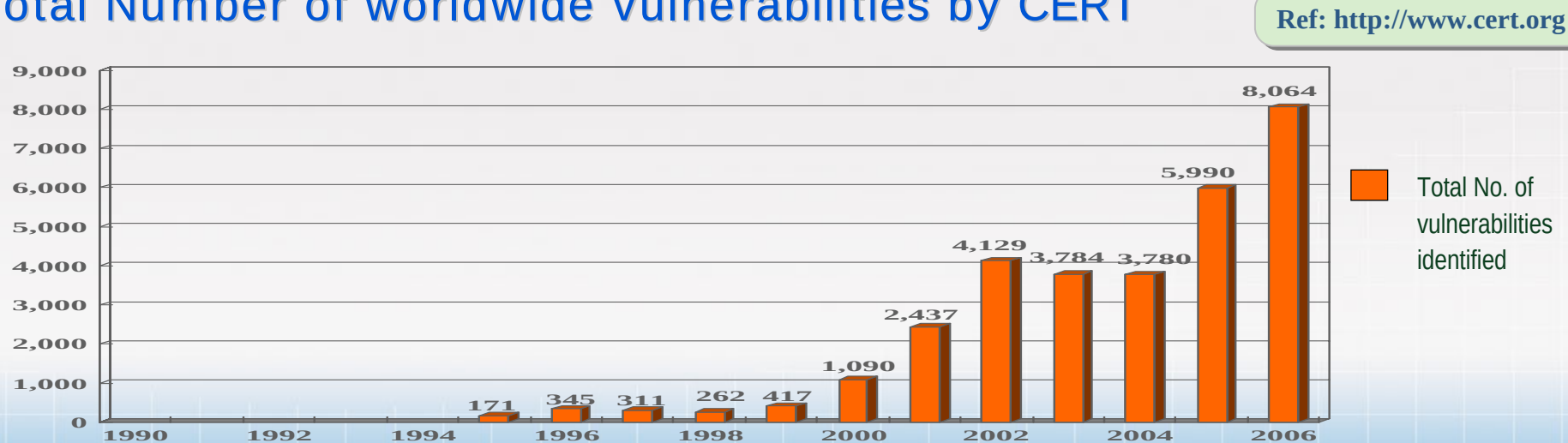
- 50,633,265 populations for 2006;
- **34,120,000 Internet users** as of Dec./06 (ranked 6th by ITU), 74.8% Internet penetration as of Dec./06 (ranked 6th by ITU as of Dec./05);
- 14,441,687 broadband subscribers as of June/07 (ranked 4th by OECD as of Dec./06); and
- 55,402,752 IPv4 addresses, 5,189 IPv6 addresses as of June/07.

Trends of cyber attacks (2/3)

Korea Internet Statistics

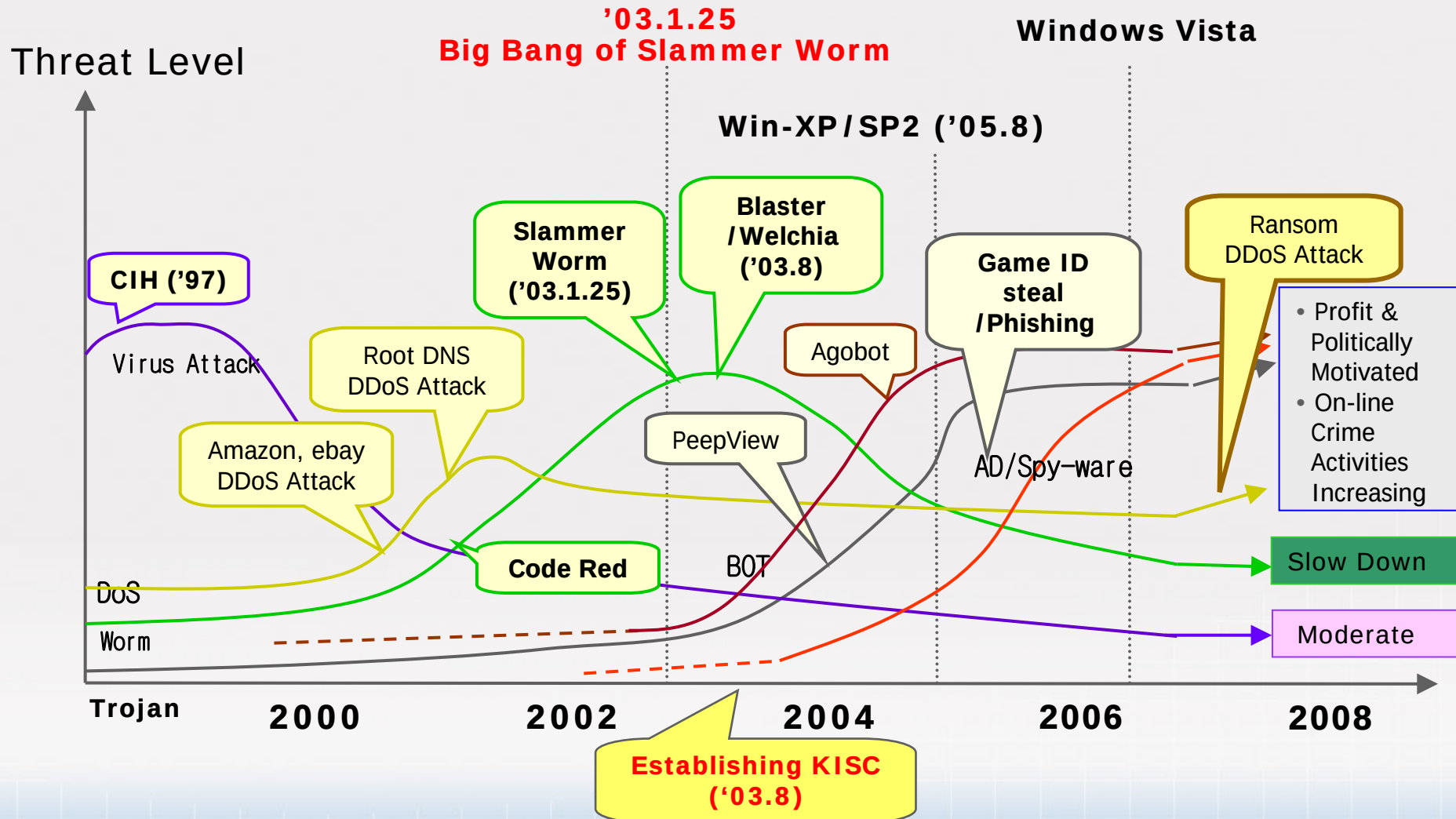


Total Number of worldwide vulnerabilities by CERT



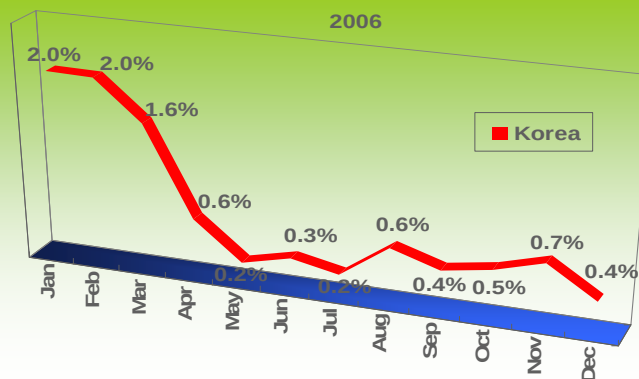
- **Korea's Cyber attack trends**
 - By Symantec's Internet security threat report, between second half of 2006, Korea was:
 - 12th highest country for the malicious code;
 - 9th highest country for the SPAM host;
 - **Second highest country for the command and control server;**
 - 9th highest country for the phishing host;
 - **11th highest country for the BOT-infected computers;** and
 - 6th country for the overall malicious activity by country.

Profile of Cyber Attacks in Korea

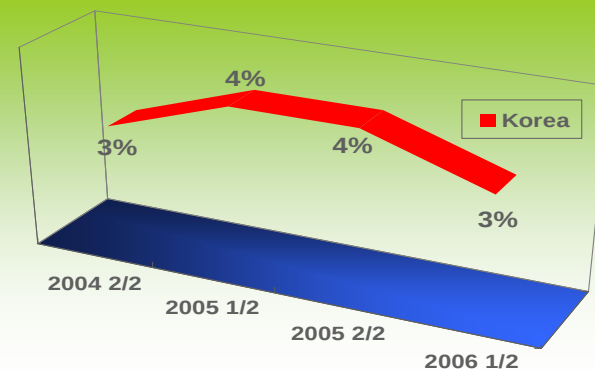


Security index trends in 2006

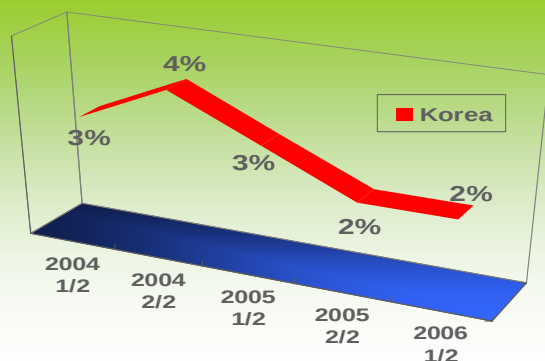
Web Page Defacement (Zone-h)



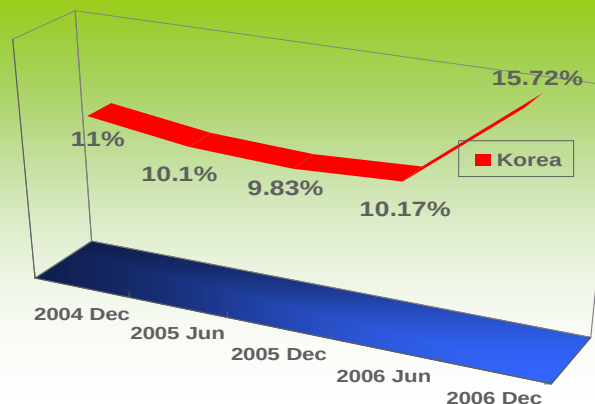
Malicious BOT Infection Rate (Symantec)



Attack Originating Korea (Symantec)



Phishing Hosting (APWG)



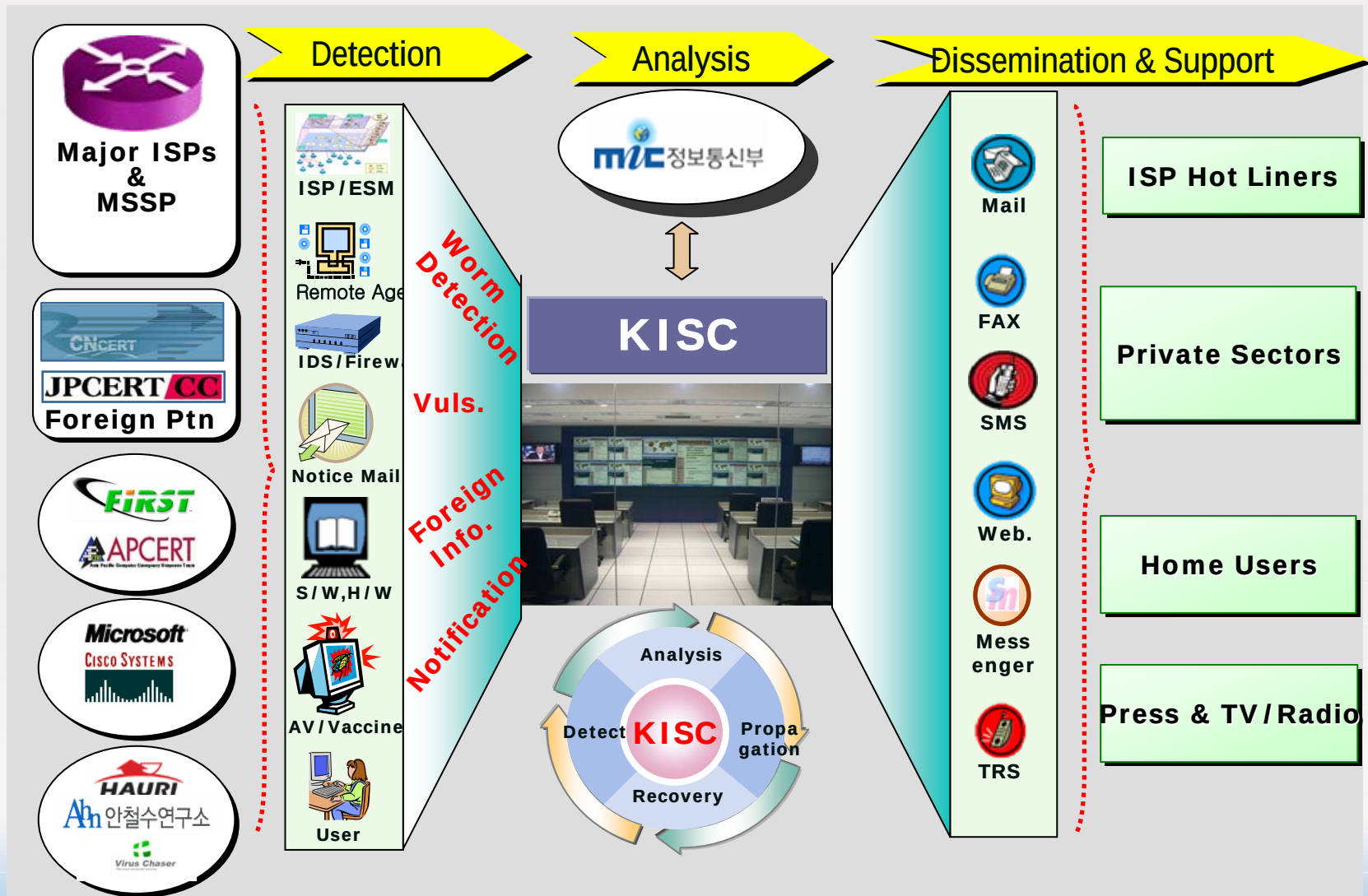
- The Slammer worm's attacks on January 25, 2003
 - Korean internet service has been shut down for at least 6 hours nationwide.
 - Too fast to respond & Too many infected servers
 - hundreds of times faster than the Code Red virus
 - infecting most of its 75,000 victims over the world within ten minutes.
 - Too widespread to coordinate
 - throughout most of Asia, Europe, and North America
- Korea's Lessons from Slammer worm's attack:
 - Revised the Act on Promotion of Information and Communication Network Utilization and information Protection to mandate the major ISPs to share incident-related information with KISC;
 - Established KISC as a information exchange hub for protecting from cyber attacks.

- **Korea Internet Security Center(KISC)**

<http://www.krcert.or.kr/index.jsp>

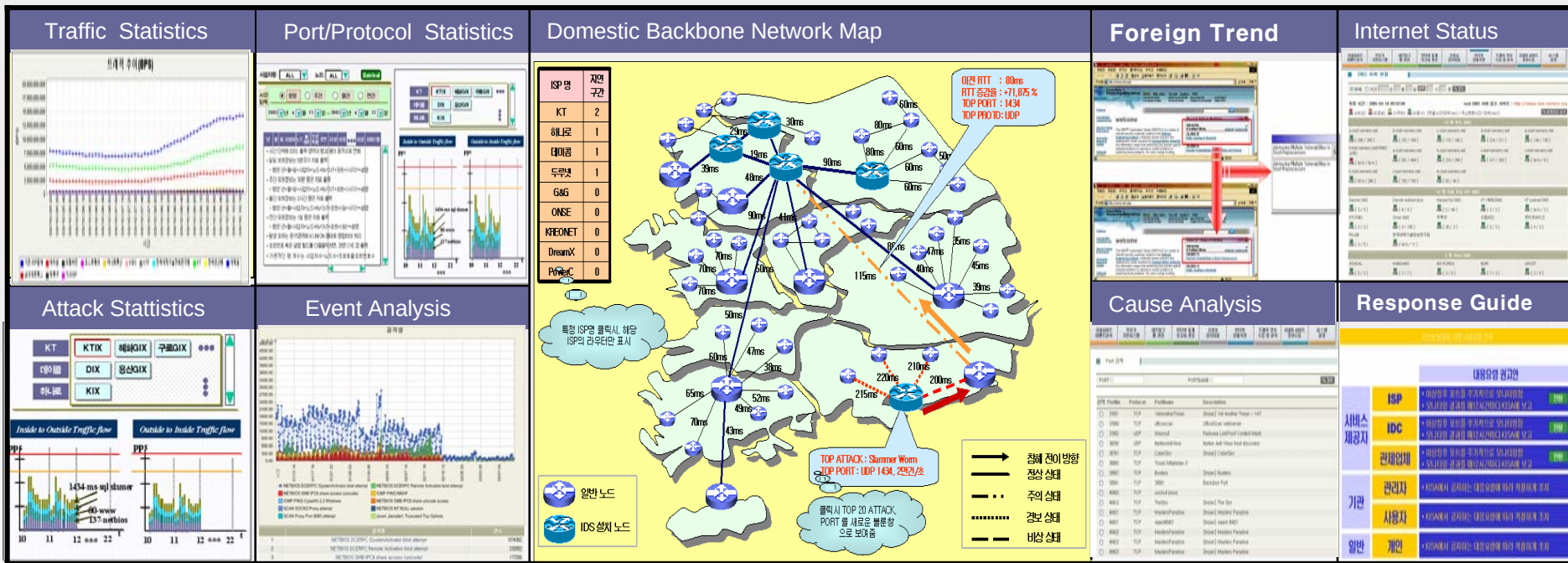
- Known as **Kr-CERT/CC**
- Established as one of departments of KISA (Korea Information Security Agency, <http://www.kisa.or.kr>) in December 2003, after having experienced the massive Slammer worm's attack over Korean Internet on January 25th, 2003.
- To prevent Korean Internet against any damages by analyzing information from various sensors deployed in ISPs, anti-virus industries, IS industries, and etc.

KISC Work Flow



Korea Internet Security Center

- Collects domestic and international information about incidents in real time;
- Monitors Korean Internet 24 hours a day, 7 days a week;
- Provides Prompt Response in case of an emergency.



- Use the following data for incident response:
 - Traffic data from Major Domestic ISP Traffic by Ports, Protocols, and Attacks;
 - Status information from Domestic major Web servers in the Private Sector;
 - Information on query statistics observed in Root DNS, KR DNS, Major Domestic ISP DNS;
 - Security-related trends from Major Anti-Virus, System, Software, and Security Company; and
 - Security vulnerabilities collected and analyzed from KISA's honnypot.
- Incident Responses:
 - Notify the victim company or organization of the incidents committed;
 - Generate and disseminate a Hacking/Virus Alert/warning; and
 - Request for Analysis and Investigation of Incidents.

Protecting nationwide network

- **Constant Network Monitoring**

- monitoring of major internet data traffics 24-hours-a-day, 7days a week.

- **Vulnerability Analysis**

- internet-related software: victim case study

- **Prompt Reaction**

- announcement of alerts in case of emergencies



- **International Collaboration**

- sharing relevant data with international bodies and national bodies like NCSC.

- **Producing important threat / security-related statistics**

- monthly data publishing of 6 items

Detailed Response activities for Cyber attacks



Classified malicious codes

Main Target

Countermeasure: 7 + 2Layer

Major Malicious Codes

Indiv.: 12 Mil.



Web sites.: 1.4 Mil
L/L Corp.: 87,000



ISP : 70 +



9. Human Intervention

8. Active Contents

7. Application

6. Presentation

5. Session

4. Transport

3. Network

2. Link

1. Physical

Human FW

Application FW

Firewall, IDS, IPS

Spyware, Phishing, Trojan

Mal. Code Inject. :ActiveX,
Scripts

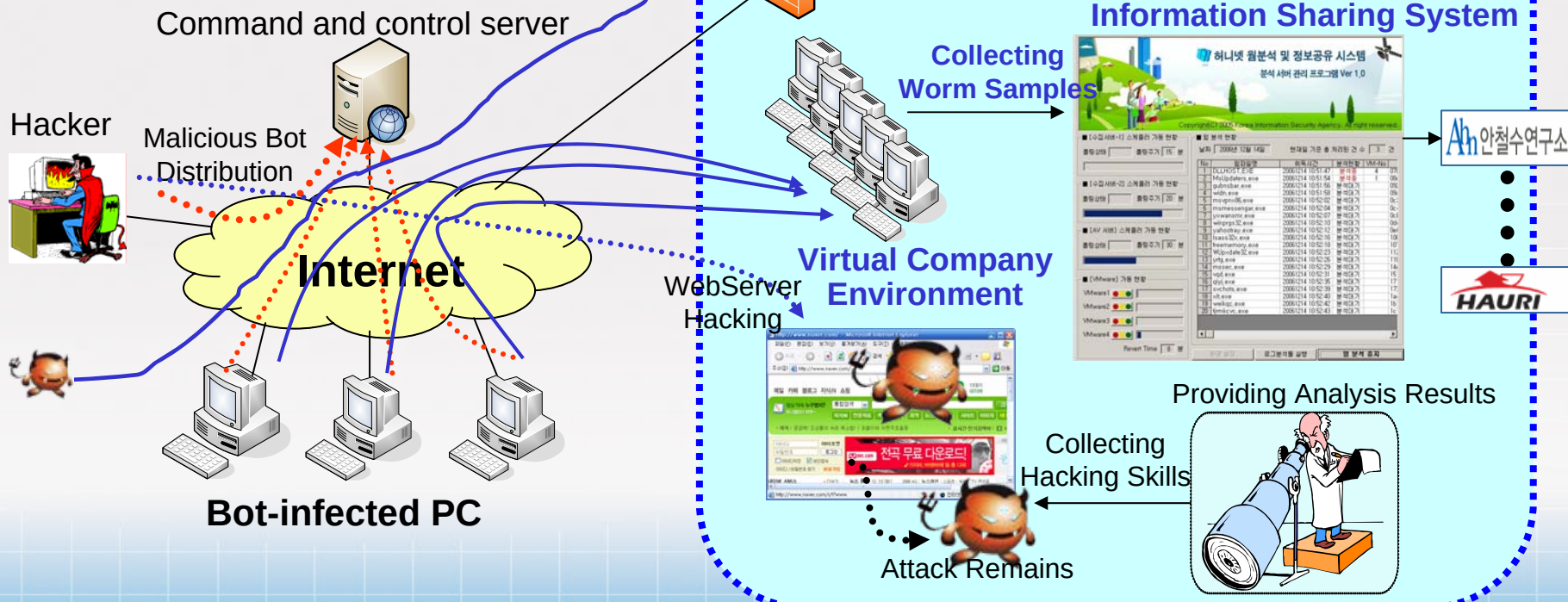
Defacement ,
SPAM-Relay

Network Attack:
BOT
SPAM,
Worm, Virus
DDoS,
Session Hijack,
Multi-Mailer,
Etc.

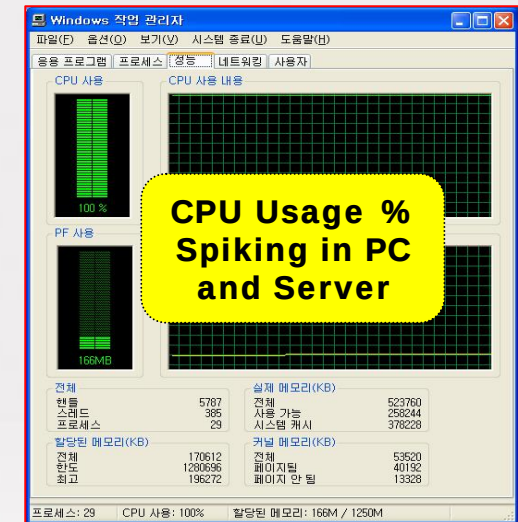
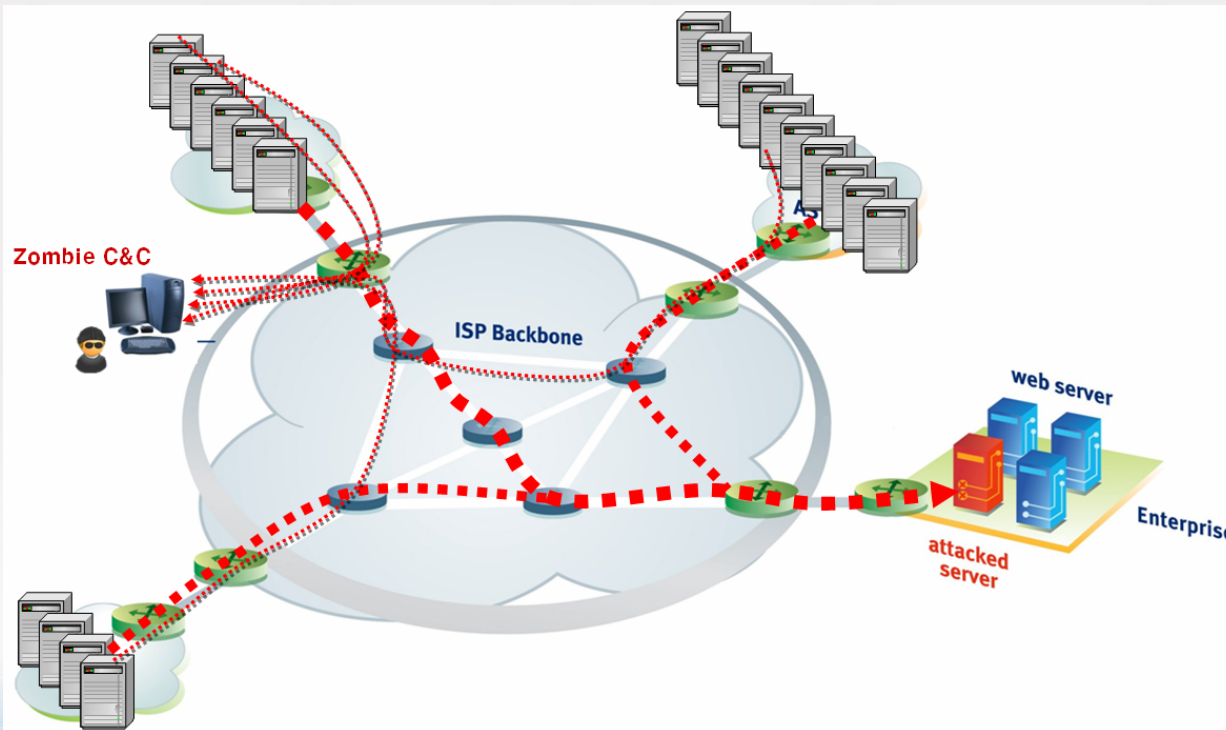
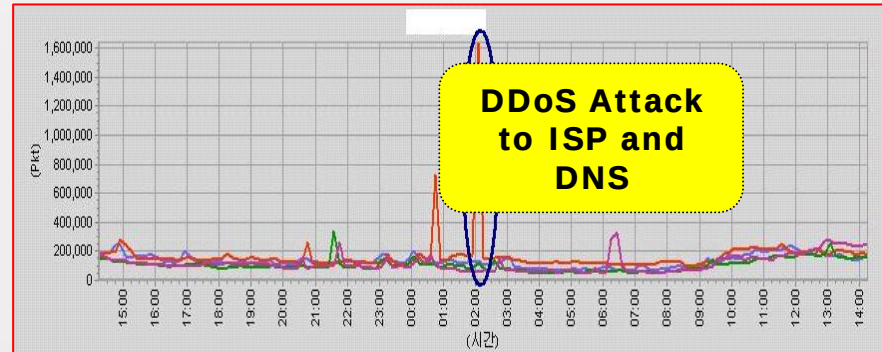
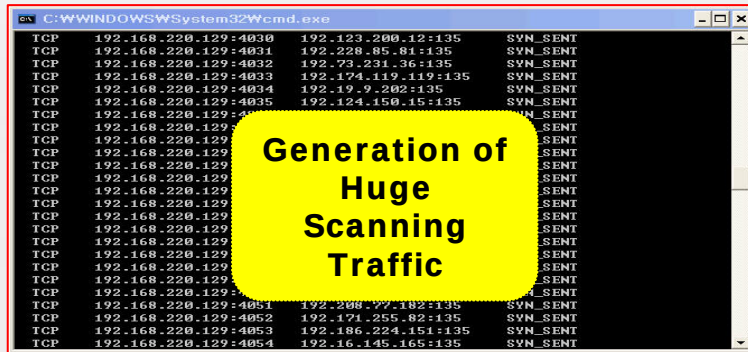
HoneyNet analysis

Key features

- System survivability analysis
- Malicious traffic analysis
- Gathering mal-ware samples
- Learning new hacking skills
- Information sharing with Anti-virus company.



Malicious BOT : Zombie network (BotNet)

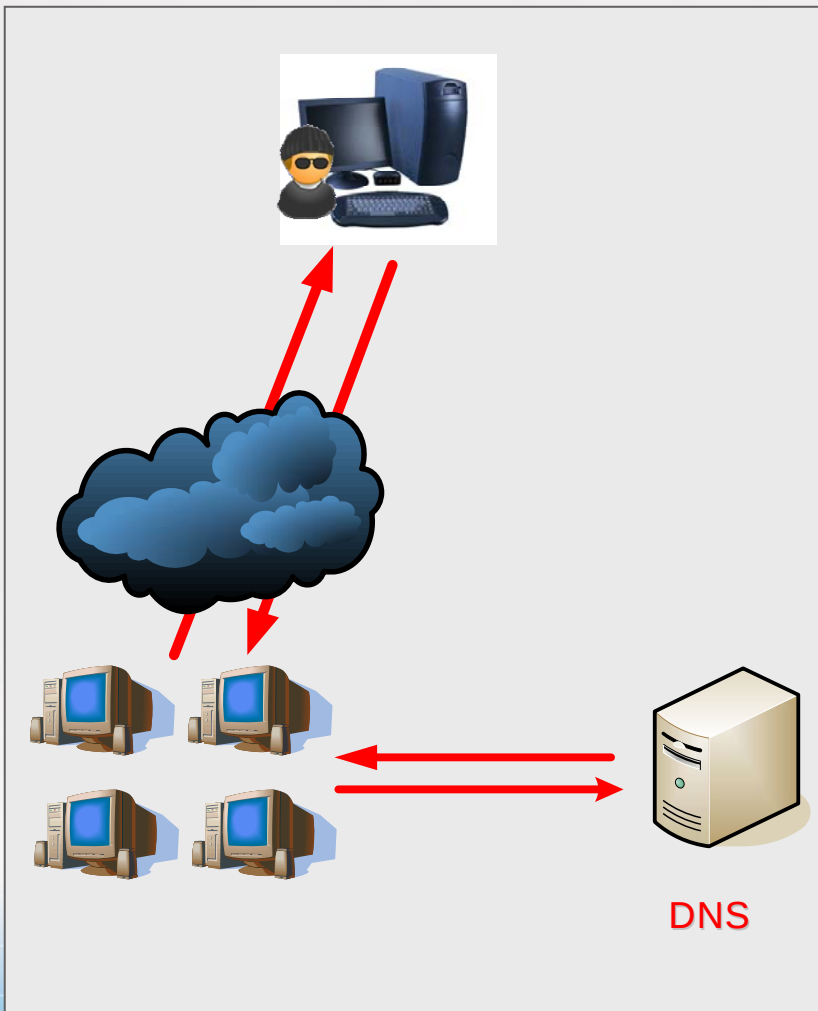


```
<_brian> .getcdkeys
<sex1-5948> Microsoft Windows Product ID CD Key: (52782-OEM-... -00538).
* sex1-4177 has quit: IRC (Client exited)
<sex1-9618> Microsoft Windows Product ID CD Key: (52782-OEM-... -00105).
<sex1-1852> Microsoft Windows Product ID CD Key: (52782-OEM-... -00102).
<sex1-5948> [C
<sex1-2609> Microsoft Windows Product ID CD Key: (52782-OEM-... -15164).
<sex1-5436> He
<sex1-7763> Microsoft Windows Product ID CD Key: (52782-OEM-... -00117).
<sex1-5702> Microsoft Windows Product ID CD Key: (52782-OEM-... -00107).
<sex1-9618> [C
<sex1-6268> Microsoft Windows Product ID CD Key: (52782-OEM-... -23206).
<sex1-1852> [C
<sex1-9469> Microsoft Windows Product ID CD Key: (52782-OEM-... -00086).
* sex1-6909 has quit IRC (Client exited)
<sex1-7965> Microsoft Windows Product ID CD Key: (55274-649-... -23825).
```

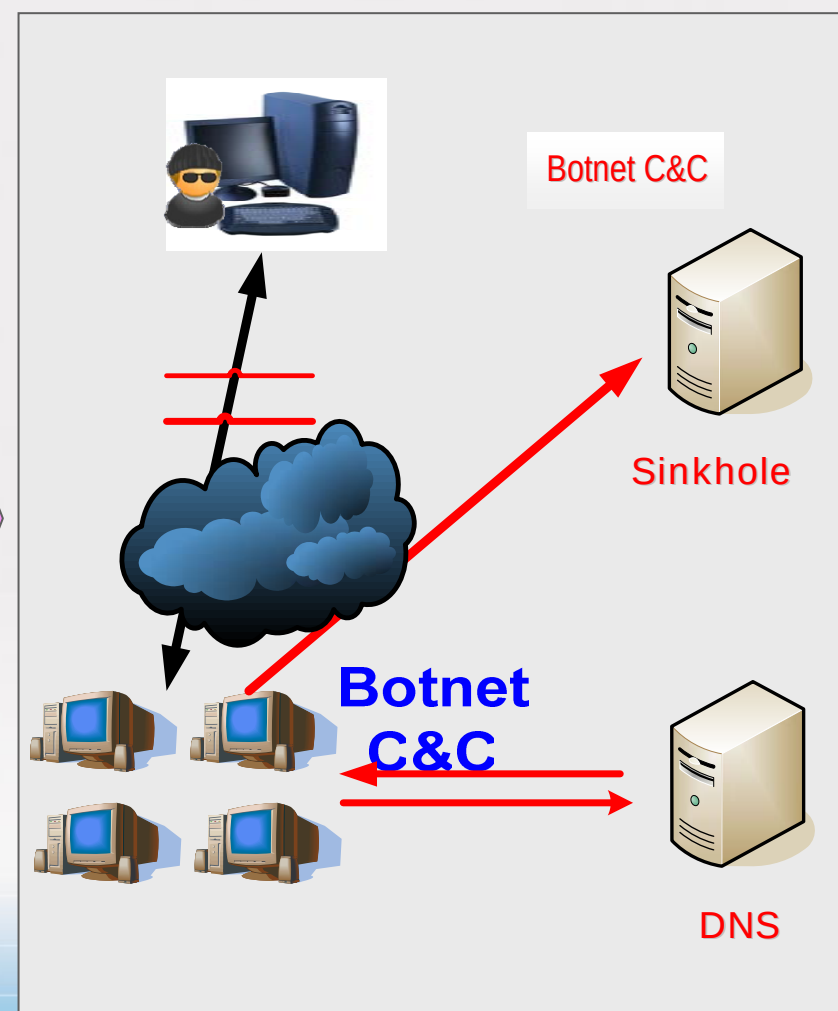
Personal Information Steal like CD-Key, ID/PW

Malicious BOT : Botnet Sinkhole Scheme

Before



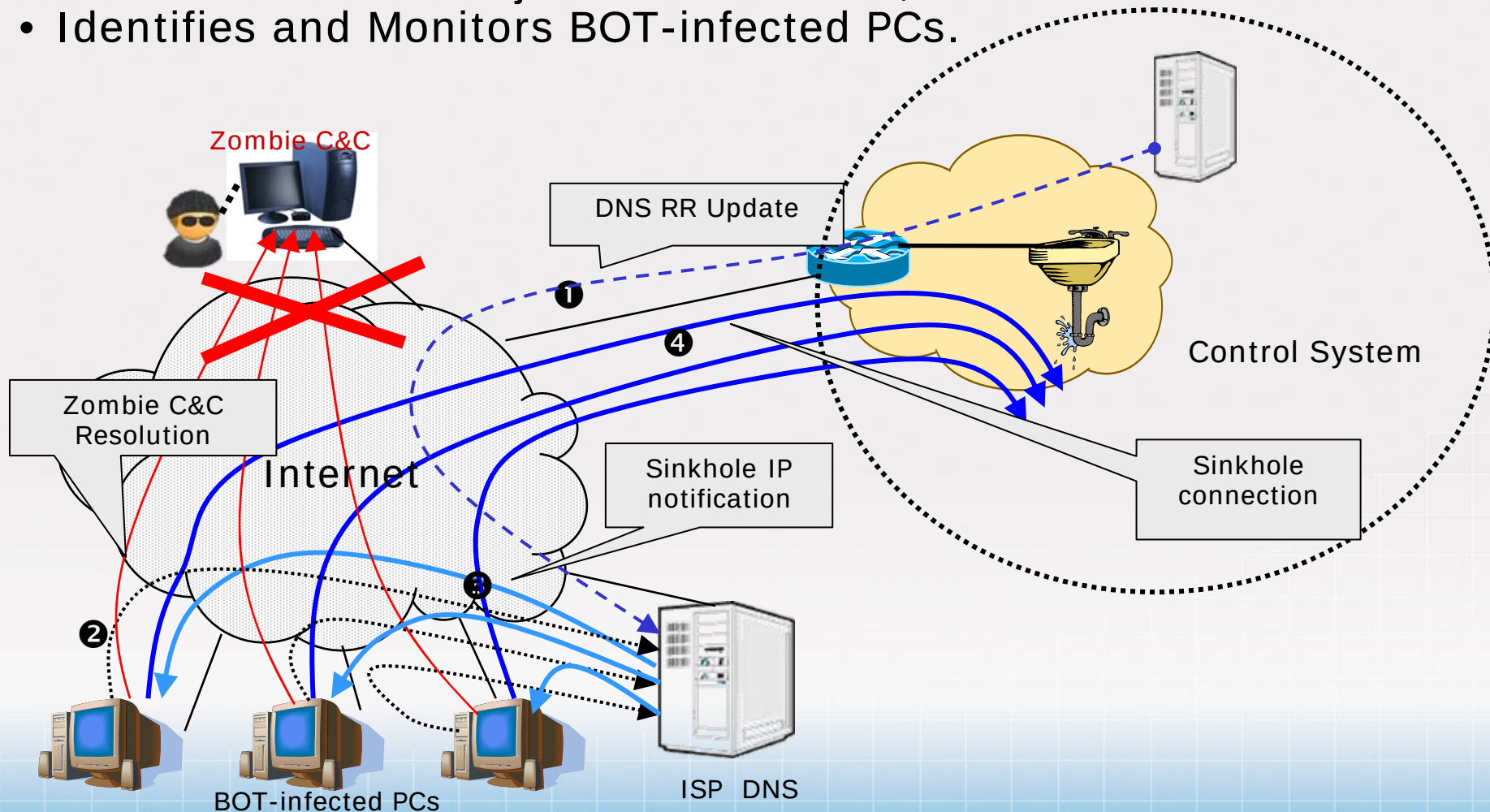
After



Malicious BOT : Operation of DNS Sinkhole

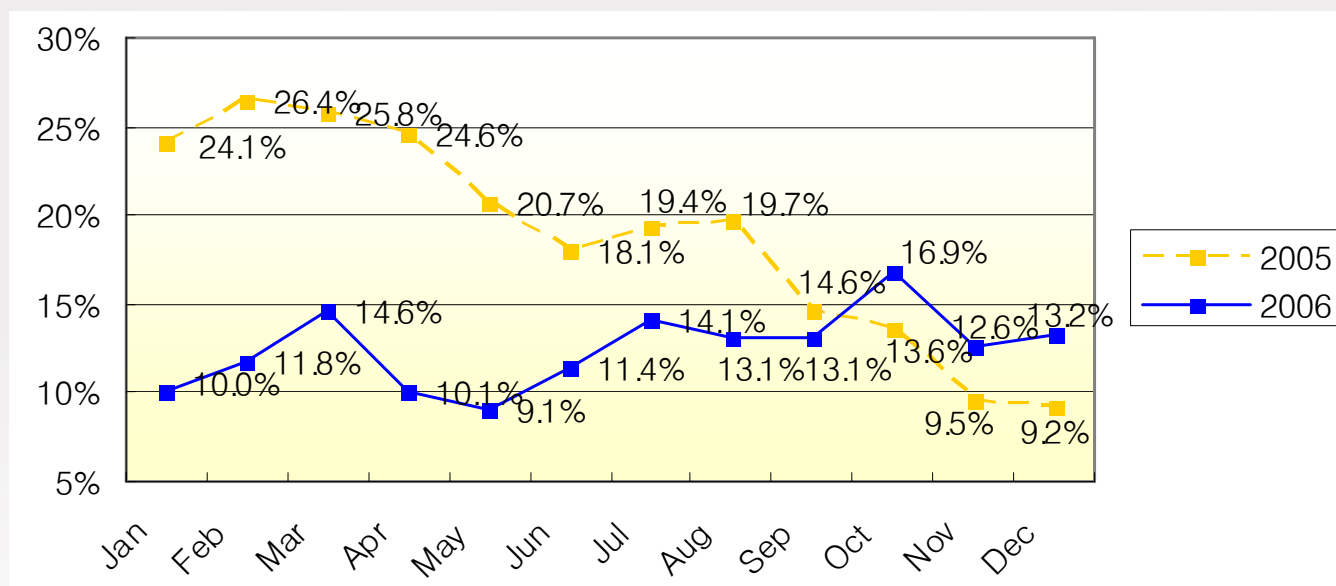
Key features

- Destroys the control mechanism of the BotNet;
- Collaborates with major domestic ISPs; and
- Identifies and Monitors BOT-infected PCs.



- Use Honeypot
 - for collecting information on BOT infections
- Analysis of DNS Query Log
 - For identifying the BOT-infected system since infected system uses specific DNS Server for querying C&C DNS RR (Resource Record)
- Analysis of Honeypot Traffic
 - Use snort and tcpdump for capturing various BOT traffics
- Deep Analysis on collected samples
 - Blackbox and Sandbox testing
- Sharing information with various relevant parties and groups
 - By exchanging information with several anti-BOT groups

- Observed in KISA's Honey pots.
- The value in the Figure represents the ratio of the BOT infections originating from Korea to the worldwide BOT infections while USA is top. That is, the 12% of BOT infected traffic comes from Korea, accounting for 12 percent of the worldwide total.



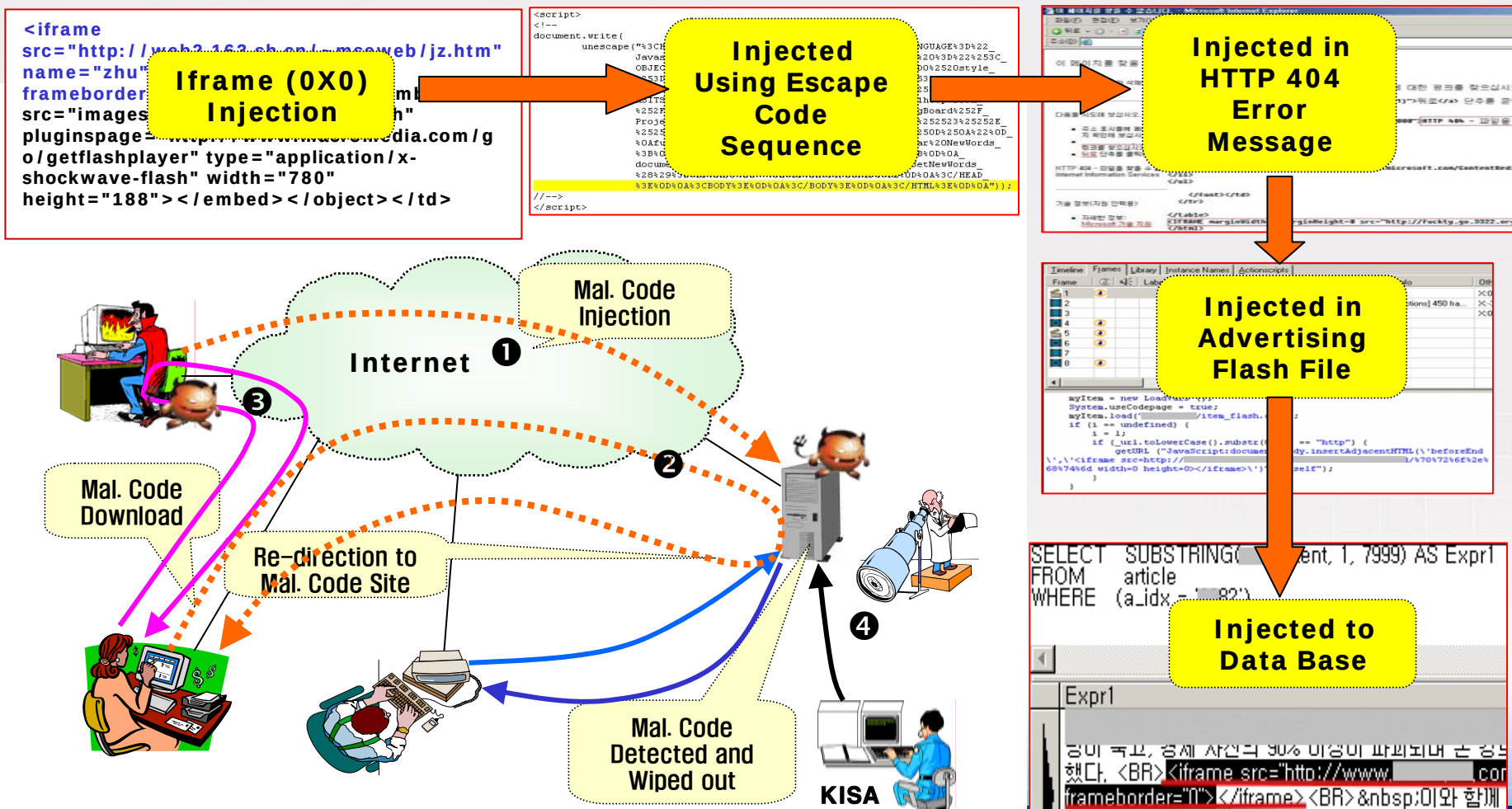
Bot Infections originating from Korea

- Promote DNS Sinkhole scheme to more ISP/SO/RO Already in place
 - Currently applied to only big ISPs like KT, Dacom, etc;
 - 5 SOs in the cable TV network in 2007;
 - RO: Relay Operator, SO: System Operator in Cable TV networks
- Deep analysis for collecting more BOT signatures Already in place
 - To find new DNS RR and other information
 - Collect BOT Samples every week
- Notifies the BOT infected IP addresses to the ISPs which the users of infected PCs belongs to. Already in place
- Consider the direct removal of BOT agent in the infected PCs sending a kill BOT commands by KISC; and
- Trace IP address of BOT C/C master (working with ISPs and relevant organizations)

MC-infected web sites(1/3)

Key features

- Finding MC-infected Web servers used as the media of spreading malicious codes to other web sites
- Monitoring major Web servers for 24 hours a day using automatic tool



- Hackers are using the compromised web site to spread malicious codes to end-user:
 - The web administrators are not aware that their sites are hacked and used to disseminate malicious codes;
 - Users also are not aware that their computers get infected by malicious codes from the sites they have visited;
 - Installing security patches and anti-virus S/W can prevent some incidents, but, they are not providing ultimate solutions.
- An automatic detection system was developed for searching MC disseminating sites.
- A total of 77,000 sites are being monitored since December 2005.
- As of April 2007, 190 web sites have been founded as MC infected sites.

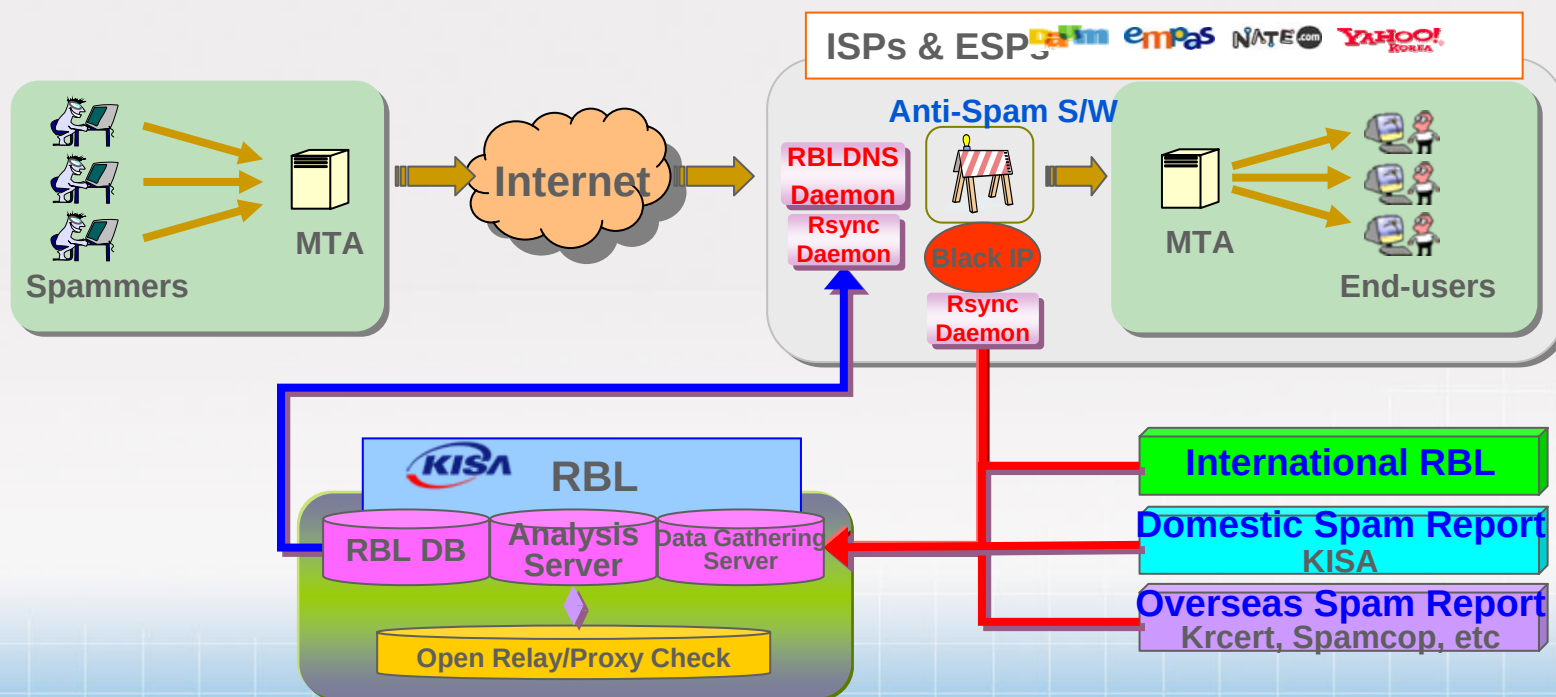
- Web sites to be inspected:
 - Major enterprise/gov./orgs, etc. sites, Popular sites (Top N Sites decided by number of visited users);
 - Sites which have experienced the web pages' defacement.
- Inspect HTML documents to determine whether an malicious code exists:
 - Detect suspicious scripts exploiting windows vulnerabilities;
 - Signature-based detection.
- List up the dissemination URLs from analysis results of HTML docs.
- As a result,
 - Inform the administrators of the infected web site by SMS or e-Mail;
 - Ask foreign CERTs to take countermeasures to break down the sites; or
 - Maintain and track the history of the MC-infected sites.

- A multi-layered approaches are necessary:
 - technical solutions;
 - user awareness;
 - appropriate legislation and enforcement;
 - industry initiatives; and
 - international cooperation.
- International cooperation
 - Seoul-Melbourne Anti-Spam Agreement
 - Signed on April 27, 2005
 - a multilateral memorandum of understanding (MoU) on cooperation in countering spam.
 - Aimed at sharing knowledge, information and intelligence about known sources of spam, network vulnerabilities, methods of spam propagation, and technical, education and policy solutions to the spam problem
- Best practice for combating SPAM between Korea and China
 - KISA informed ISC, China of the IP addresses of spammer in China
 - Banned the spammer from using the IP addresses on December, 2005

- Types of SPAM
 - E-mail SPAM & Cellular Phone SPAM
- Two kinds of means to combat SPAM
 - Technical means for SPAM
 - Regulatory means for SPAM
- Technical means for combating E-mail SPAM
 - Use real-time SPAM back list
 - Use Sender Policy Frame (SPF) for combating e-mail SPAM
- Adopted “Opt-IN” regulation since March 31, 2005.
 - Average 0.99 cellular phone’s SPAM per user everyday, in the first half of 2006.
- Countermeasures for combating Cellular Phone SPAM
 - Use SPAM trap deployed by KISA and Revise the relevant law on March 25, 2007, to inform the policy agency of the illegal Spammer’s list collected by SPAM trap deployed by KISA and provide a framework to share the SPAM black lists between ISPs, July 2007.
- Survey performed March 15 – 16 revealed that
 - Every cellular phone user receives average 0.53 cellular SPAM every day .

Key features

- Gathering SPAM-related information from major Mail Service Providers, and taking into account domestic/overseas Spam Reports to KISA, and International SRBLs
- The SRBLs are Updated at a periodic interval **and** distributed to RBLDNS daemon in front of MTA and Updated as frequent as possible

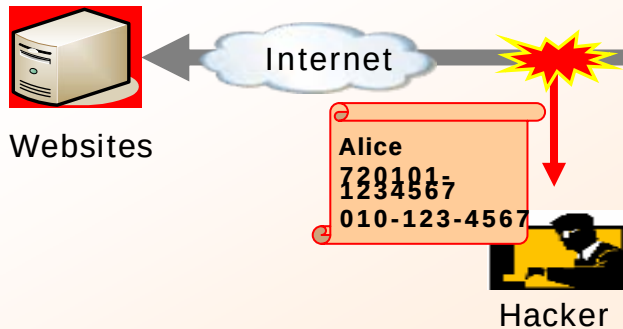


- Adopted the Sender Policy Framework (SPF) since August 2005.
- **Sender Policy Framework (SPF)**
 - to prevent the delivery of spam messages with fake sender's information.
 - allows software to identify and reject forged addresses in the SMTP MAIL FROM (Return-Path), a typical nuisance in e-mail SPAM.
 - SPF is publishing "reverse MX" records in DNS which tells the mail sender when machines send mail from the domain.
 - The recipient of the e-mail can now check these records to ensure that e-mail is coming from a "trusted" sender from this domain.
 - These "reverse MX" records can be easily published in DNS.
 - SMTP receivers verify the sender address of sending MTA and

- Promoting adoption of SPF
 - Major 10 Mail Service Providers published SPF records on their DNS, as of October 2005
 - Promote SPF to extend it to both private and public sectors over the next a couple of years
- Expected benefits from adoption of SPF
 - Blocks spam messages directly sent from Spam-Mailer or BOT-Net
 - Considerably reduces load of MTA and/or Anti-Spam S/W
 - Complements structural vulnerability of SMTP

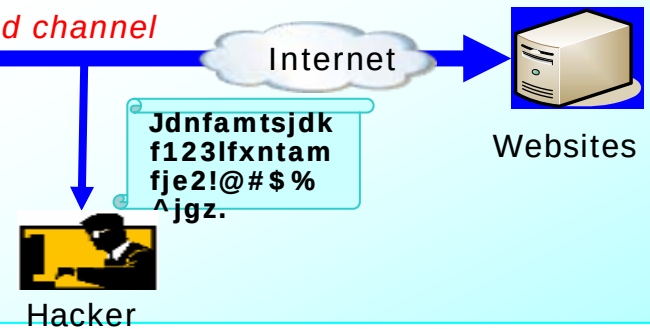
Secure SSL/Web Server

[Without secure web server]



[with Secure web server]

Encrypted channel



- Based on Act on Promotion of Information and Communication Network Utilization and information Protection (article 28)

Promotes the awareness for protecting personal information

Awareness

Infrastructure for secure server

Provides a economic SSL certificate or products for deploying secure server or web server

Big demand

Recommends public sector to adopt it firstly, the private sector later

2,000(43rd) as of
2005 by WEF



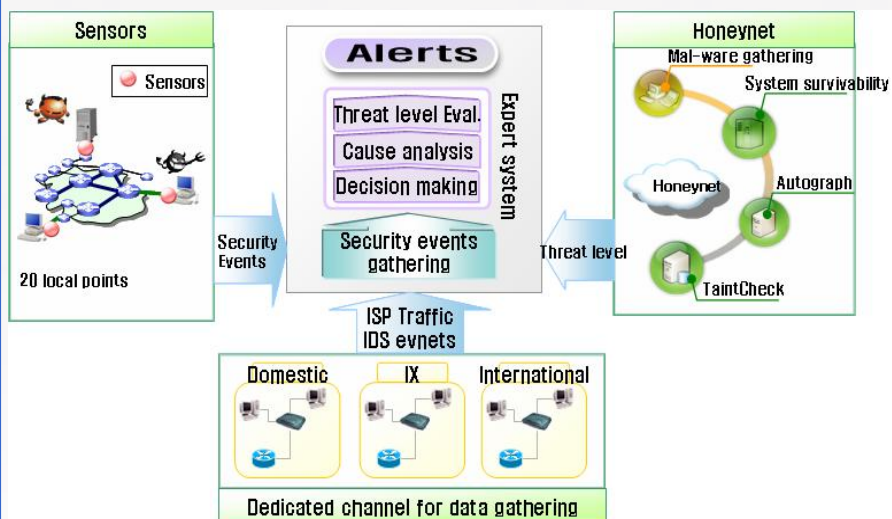
30,000(Top 5) as
of 2007 by WEF

Next Generation Incident Response

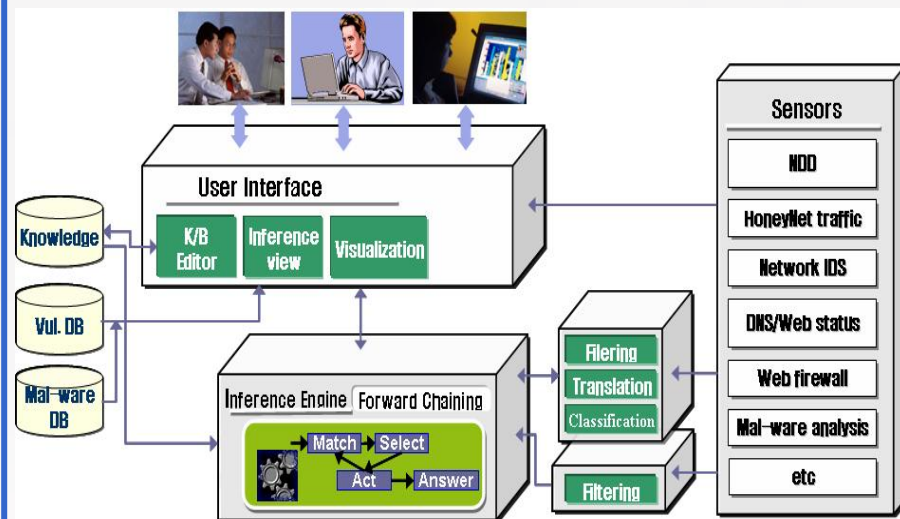
Next Generation Security Incident Response System

- Intelligent response system in the view of the nationwide network security;
- Achieving the fast response process against Zero-day, DDoS, and Ransom attacks to at least 15 minutes;
- Incident prevention technique based on the on-demand threat management.

Environment of the system deployment



Knowledge-based response system



Vision and goal for information security



- **Fundamental Strategy for Ubiquitous Information Security** published by MIC on December 31, 2006:
 - Vision&Top 4 Priority policies were established;
 - Strategic promotion of R&D and technology development;
 - Strengthen the global competitiveness of Korean Industries;
 - Improvement of the existing Legal/regulatory system.

Secure and safe ubiquitous society



Secure Infrastructure

- Developing more efficient incident-response systems
- Minimizing threats in Internet including BcN and USN
- Protecting Critical Infrastructure from cyber attacks

Trusted Service / devices

- Developing new U-authentication and u-ID management systems
- Developing techniques making u-device trusted and u-IT service secure in a converged environments
- Providing a base for secure e-transactions

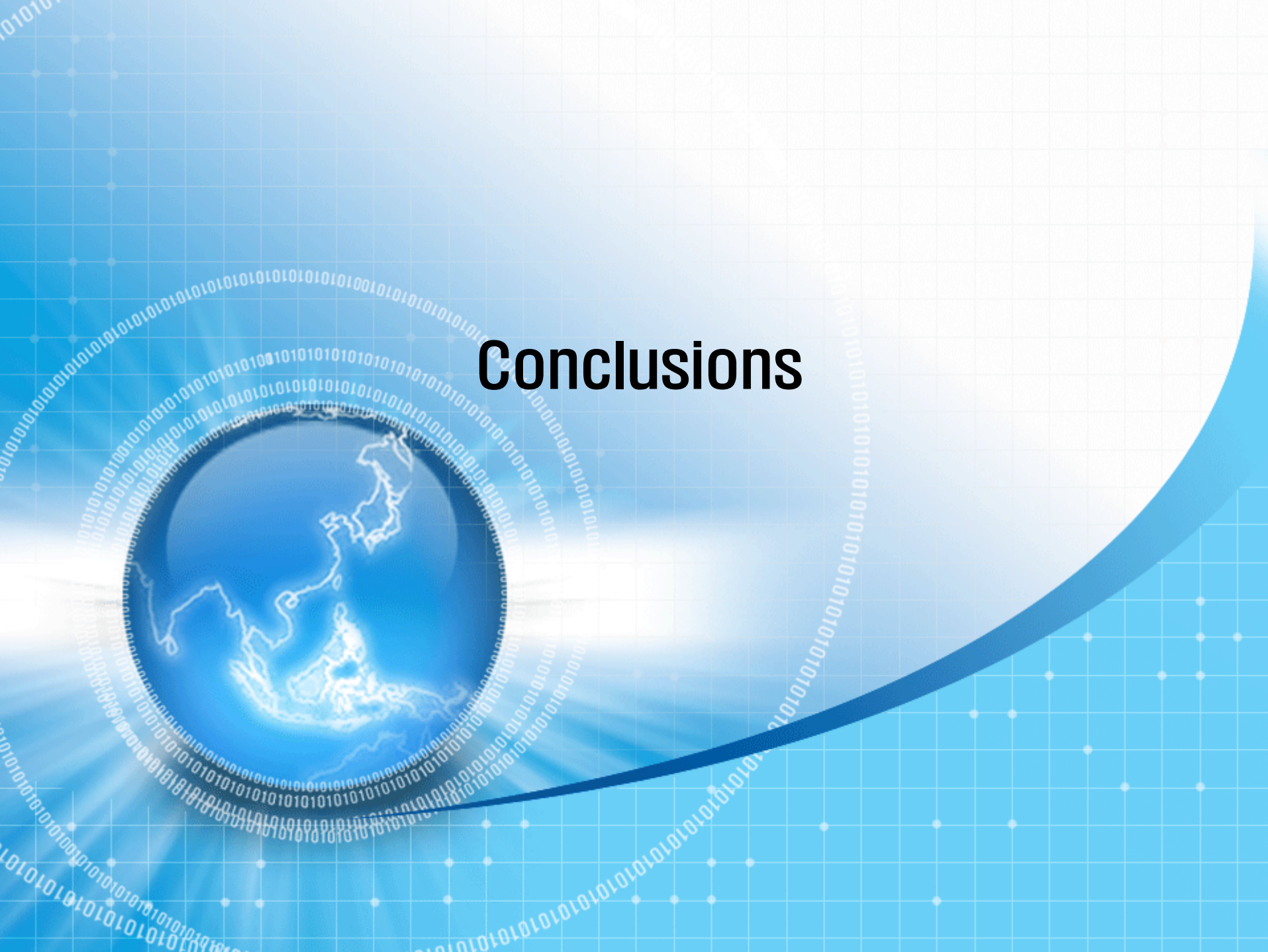
Privacy protection of user

- Privacy protection of location information
- Protection of biometric and health care information
- Protection of CCTV, RFID-related usage information

Clean Internet environment

- Protecting the dissemination of illegal / harmful traffic in the Internet.
- Spreading U-clean Internet culture.
- Raising user's awareness about clean internet culture.

Conclusions



- Since there is no border of cyber attacks, it should be recommended to strength the international cooperation with relevant partners for preventing cyber attacks.
- Best security practices should be shared among the relevant organizations.
- Various network-based sensor information including the amount of traffic flow, the signature of worm, and virus, should be shared across the relevant organizations beyond the countries or economies.
- In addition, national or international standard activities are very critical to stabilize IT system or allow the IT system to be interoperable by instituting more efficient coordination.
- Encouraged to promote global, consistent, and interoperable processes for sharing incident-response related information(in Resolution on cyber security at Kobe July 2007 GSC12 meeting).

**Thank you very
much for your
attention**

